

Teamder — Email Auth Upgrade Compatibility Audit

25.09.2026 · תכנון בלבד · אפס שינוי קוד, קונפיג, deploy או מוטציית Auth

תיקון לדוח Phase 0.3 — קודם כול, כי הוא משנה את כל השאר

הבדיקה שלי ב-0.3 פגעה ב-endpoint הלא נכון, והמסקנה שהסקתי ממנה שגויה.

השתמשי ב-accounts:update, שזה מסלול שינוי אימייל. קריאת מקור ה-SDK מראה ש-

linkWithEmailPassword קורא ל-linkWithCredential>EmailAuthProvider.credential(...) , שפוגע ב-

endpoint אחר לגמרי, שאינו כפוף למדיניות שינוי-האימייל. הודעת השגיאה אמרה "before changing"

email" וזה היה הרמז; לא שקללתי אותו מספיק.

לכן: הקביעה "שדרוג אורח→אימייל צפוי להיכשל בפרודקשן" נסוגה.

הראיות כעת מצביעות על כך שהוא תקין.

אבל התגלה משהו אחר, והוא אמיתי

מסלול האימייל בגיליון

לא קורא ל-linkWithCredential בכלל.

הוא מנווט ל-EmailAuthScreen, שקורא ל-createUserWithEmailAndPassword

חשבון חדש, ה-UID האנונימי נזנח.

כלומר אופציה B כבר ממומשת בפועל, בלי שנבחרה. וענף ה-email ב-authUpgrade.acquire() הוא

קוד מת

— אף אחד לא קורא לו.

Current Email flow 1

```
ContextualAuthSheet.attempt('email')
├─ onCancel(); nav.navigate('EmailAuth') ← upgradeAnonymous לא
├─ EmailAuthScreen
│   └─ signUpWithEmail → userService → fbSignUpWithEmail
│       └─ createUserWithEmailAndPassword() ← חדש UID, חשבון חדש
│           + sendEmailVerification() (best-effort, לא חוסם)
│           + setDoc(/users/{newUid})
└─ signInWithEmail → signInWithEmailAndPassword() ← קיים UID

authUpgrade.acquire('email', ...) → EmailAuthProvider.credential(...) ← DEAD CODE
authUpgrade Case A/B (linkWithCredential) ← בלבד Google/Apple
```

תשובה

שאלה

best-effort אבל הוא Password signup בלבד. אין Email Link בשום מקום. יש sendEmailVerification ואינו חוסם שימוש. Password signup / Email ?Link / verification

→ :122 → attempt('email') → ContextualAuthSheet.tsx:217 אחד: email שמגיעים ל-callsites מהגיליון nav.navigate('EmailAuth'). זה הכול.

קורא ל-ContextualAuthSheet.tsx:131 אף אחד. upgradeAnonymous(method) קורא ל-authUpgrade עם upgradeAnonymous?email שנקף ה-email כבר יצא ב-return.

מקור ה-SDK, @firebase/auth 1.13.1, מפריד בין שלושה מסלולים שנראים דומים:

```
linkEmailPassword(auth, req)    → POST /v1/accounts:signUp          ← linkWithCredential(email,pwd)
updateEmailPassword(auth, req)  → POST /v1/accounts:update        ← updateEmail / updatePassword
verifyBeforeUpdateEmail(user, e) → sendOobCode VERIFY_AND_CHANGE_EMAIL

// מעל , מעל
// "Used for linking an email/password account to an existing idToken.
// Uses the same request/response format as updateEmailPassword."
```

שתי הפונקציות חולקות פורמט בקשה זהה אבל פוגעות ב-**endpoints שונים**. זה מה שהטעה אותי: שחזרתי את ה-payload נכון ואת היעד לא.

מה נבדק ב-0.3	מה האפליקציה עושה
POST accounts:update {idToken,email,password}	POST accounts:signUp {idToken,email,password}
— OPERATION_NOT_ALLOWED לא נבדק מדיניות שינוי אימייל	

מה `enableImprovedEmailPrivacy` באמת עושה
הוא לא חוסם קישור. השפעותי הידועות: `fetchSignInMethodsForEmail` מחזיר מערך ריק, ושגיאות התחברות נעשות גנריות (`INVALID_LOGIN_CREDENTIALS` במקום `INVALID_PASSWORD / EMAIL_NOT_FOUND`). `accounts:signUp` ממשיך להחזיר `EMAIL_EXISTS`, אחרת הרשמה לא הייתה עובדת כלל — ו-
25 חשבונות `password` בפרודקשן מוכיחים שהיא עובדת.

מה כן נשבר בפועל מהמדיניות

מקום	חומרה	המצב
auth.ts:246 — <code>fetchSignInMethodsForEmail</code> בענף הקולישן	נמוך	קוד מת בפועל. מחזיר [], ולכן <code>EmailRegisteredWithProviderError</code> לעולם לא נזרק. ה- <code>catch</code> נופל דרכו בשקט לשגיאה הגנרית.
EmailAuthScreen.tsx:109	כבר מטופל	יש שם הערה מפורשת: "Email-enumeration protection makes the provider undetectable". המסך מציג הודעה שמכסה את שני המקרים ומציע לעבור להתחברות. מישור כבר ידע.

3 Firebase SDK capabilities בפרויקט

יכולת	זמין?	הערה
firebase / @firebase/auth	1.13.1 / 12.13.0	גם @react-native-firebase/auth 24.0.0 (session נייטיב מקבילה)
linkWithCredential (email/password)	כן	accounts:signUp →

יכולת	זמין?	הערה
sendSignInLinkToEmail + credentialWithLink	כן	הקישור מגיע ל- signInWithEmailLinkForLinking — מסלול קישור — idToken עם accounts:signInWithEmailLink שמאמת את האימייל מעצם בנייתו
verifyBeforeUpdateEmail	קיים	לא רלוונטי לאורח. ראו מתחת
reCAPTCHA enforcement	recaptchaConfig: null	handleRecaptchaFlow לא יחוסם
Dynamic Links	לא בשימוש	וטוב — Google סגרה אותם 25.08.2025

למה verifyBeforeUpdateEmail אינו הפתרון

```
request = { requestType: 'VERIFY_AND_CHANGE_EMAIL', idToken, newEmail }  
// ואחריו: if (email !== user.email) await user.reload();
```

הוא בנוי סביב שינוי אימייל קיים: ה-requestType אומר זאת, והקוד משווה ל- user.email. לאורח אנונימי אין email ואין ספק סיסמה, ואין לו סיסמה שתאפשר התחברות אחרי האימות. גם אם הקריאה הייתה עוברת, היא לא מצמידה ספק — היא לא הופכת אורח לחשבון.

4 Option A — שמירה על Improved Email Privacy + קישור תואם-אימות

Email Link (passwordless), לא סיסמה. זה המסלול היחיד שמאמת את האימייל מעצם מבנהו, ולכן אינו מתנגש עם שום מדיניות פרטיות.

```
אורח מקיש אימייל
→ sendSignInLinkToEmail(auth, email, actionCodeSettings)
→ האדם פותח את המייל ולוחץ
→ (App Link / Universal Link) הקישור חוזר לאפליקציה
→ isSignInWithEmailLink(link)
→ linkWithCredential(user, EmailAuthProvider.credentialWithLink(email, link))
  ↳ accounts:signInWithEmailLink { idToken, email, oobCode } ← אותו UID
```

מה נדרש	פירוט
Firebase Auth config	<code>teamderfc.web.app</code> אינו ברשימת ה- <code>authorized domains</code> . הרשימה: <code>localhost</code> , <code>soccer-app-52b6b.web.app</code> , <code>soccer-app-52b6b.firebaseio.com</code> ועוד 5 ערוצי preview. חייבים להוסיף אותו — או להשתמש בדומיין שאין לו קישור אפליקציה.
AASA (iOS)	נתיבים נוכחיים: <code>/session/*</code> , <code>/team/*</code> , <code>/app</code> . צריך נתיב חדש.
Android intent filters	pathPrefixes נוכחיים זהים. צריך נתיב חדש ב- <code>app.json</code> → <code>build</code> חדש.
Hosting	דף נחיתה לקישור + עדכון <code>.well-known</code> .
אחסון ביניים	יש לשמור את האימייל מקומית לפני היציאה, כי <code>credentialWithLink</code> דורש אותו בחזרה.

עלות שיוני `build` + `hosting` + `config` חדש בשתי החנויות. זה מוציא את הפתרון מלוח הזמנים של הריפקטור הנוכחי.

5 Option B — אימות יוצר/נכנס לחשבון בנפרד, ואז מעבירים PendingAction

זה מה שהמערכת עושה היום, מבלי שנבחר. `createUserWithEmailAndPassword` / `signInWithEmailAndPassword`, ה-UID האנונימי נזנח, וה-`PendingAction` עובר לחשבון החדש.

מה שהופך את זה לעובד הוא שאורח לא מחזיק כלום: `buildGuestUser` לא יוצר מסמך `/users`, וכל נתיב כתיבה חסום מאחורי `ensureNotGuest`. אין נתונים למזג, ולכן הסיבה הרגילה לחשוש מנטישת UID לא קיימת. זה בדיוק הנימוק שכתוב בראש `authUpgrade.ts` עבור Case B.

עלות אפס — אין מה לממש. לכל היותר ניקוי: הסרת ענף ה-`email` המת מ-`acquire()` והפיכת ההתנהגות למכוונת ומתועדת.

6 Option C — להסיר Email כאפשרות שדרוג לאורח

להשאיר Google/Apple בגיליון, ולא לגעת ב-`Email login` לחשבונות קיימים.

הנתונים: `google.com` · 507 · `apple.com` · 156 · `password` · 25 · אנונימי 417. כלומר 663 מתוך 688 החשבונות האמיתיים (96.4%) הם Google/Apple. אימייל הוא 3.6%.

עלות נמוכה טכנית, אבל מסירה מסלול שעובד היום — וזו רגרסיה מוצרית עבור מי שאין לו Google/Apple, ובעיקר על Android שאין בו Apple.

אפשרות	אותו UID?	מה קורה
A — email link	כן	<code>accounts.signInWithEmailLink</code> עם <code>idToken</code> מקדם במקום. ה-session לא נפלת, המסך לא נעקר.
B — היום	לא	UID חדש. ה-UID האנונימי נותר יתום ב-Auth. זו החלטה מכוונת ב-Case B: מחיקתו הייתה מוסיפה נקודת כשל ברגע הרגיש ביותר, ובלי מסמך <code>/users</code> הוא אינו ישות עסקית.
C	כן, ל-Google/Apple	הם מקשרים דרך <code>signInWithIdp</code> עם <code>idToken</code> — Case A.

PendingAction continuity 8

שורדת בכל שלוש האפשרויות — וזה לא במקרה
`const KEY = 'footy.pending.action'` . מפתח
אחד, ברמת המכשיר, שאינו משויך ל-UID
. גם `draftStore` אינו מכיל שום התייחסות ל-uid. לכן החלפת חשבון אינה נוגעת בהם כלל.

`authUpgrade` אינו קורא ל-`clearAll` ואינו נוגע ב-PendingAction בשום נתיב — לא בהצלחה, לא בכשל, לא בביטול. מי שמנקה הוא `actionCoordinator`, ורק על תוצאה עסקית **טרמינלית**.

ההשלמה האוטומטית אחרי אימות עובדת גם היום עבור מסלול האימייל, דרך ה-`boot pass` ב-`RootNavigator:274`: הוא רץ כש-`currentUser` אינו אורח ו-`hasCompletedOnboarding` אמת, ומדווח את התוצאה דרך `reportResumeOutcome`. הגיליון אפילו מתעד זאת: "the pending action is already persisted, so the resume happens when that screen's sign-in lands".

Existing-account collision 9

אפשרות	ההתנהגות
A	<code>linkWithCredential</code> זורק <code>auth/credential-already-in-use</code> → <code>isAlreadyInUse</code> תופס → Case B: <code>signInWithCredential</code> עם ה-credential שחוזר על השגיאה, בלי לבקש אימות שני. PendingAction נשמר.
B — היום	<code>EmailAuthScreen</code> → <code>auth/email-already-in-use</code> מציג דיאלוג ומציע לעבור להתחברות. דורש פעולה מהאדם , אינו אוטומטי. PendingAction נשמר.
C	Case B → Google/Apple אוטומטי, כמו A.

`signIn.allowDuplicateEmails` נעדר מהקונפיג → **חשבון אחד לכל אימייל**. זה מה שהופך קולישנים לאפשריים מלכתחילה.

שאלה פתוחה שאיני יכול לסגור בלי מוטציה

`auth/account-exists-with-different-credential` — `authUpgrade` מטפל בו במפורש ו
לא

כ-`already-in-use`, כי אי אפשר לפתור אותו בחזרה על אותו credential. תחת email enumeration protection ייתכן שהשגיאה הזו מדוכאת או מוחלפת בגנרית. לא בדקתי, כי זה דורש יצירת חשבונות.
ראוי לאמת לפני שנשענים על הענף הזה.

אפשרות	מה נדרש
A	authorized domain חדש + נתיב חדש ב-AASA + intent filter חדש + דף build + hosting. וגם: חוזרים מהמייל — ולכן כל מטריצת הכשלים בסעיף 11 נפתחת.
B	כלום. אין יציאה מהאפליקציה. <code>sendEmailVerification</code> נשלח כ-best-effort ואינו חוסם דבר.
C	כלום.

Failure / recovery matrix 11

תרחיש	Option A (email link)	Option B (היום)
ביטול	אין קישור. PendingAction נשאר. שקט.	חזרה אחורה מהמסך. PendingAction נשאר.
קישור פג	<code>auth/invalid-action-code</code> . צריך UX לשליחה מחדש — לא קיים.	לא רלוונטי
מכשיר אחר	התרחיש הקשה. האימייל נשמר מקומית; במכשיר השני הוא חסר. Firestore דורש לבקש את הכתובת שוב — ובכל מקרה ה-UID האנונימי נמצא רק במכשיר המקורי, כך שהקישור שם לא יתבצע.	לא רלוונטי — הכול במסך אחד
האפליקציה נהרגה	הקישור עדיין תקף; חזרה מפעילה את הזרימה מחדש. ה-session האנונימית משוחזרת ולכן ה-UID נשמר.	PendingAction על הדיסק, ה-boot pass מרים
כשל רשת	שליחה נכשלת → ניתן לנסות שוב. חזרה נכשלת → הקישור עדיין תקף.	שגיאה מפורשת, ניסיון חוזר
אימייל כבר בשימוש	Case B אוטומטי	דיאלוג + מעבר ידני להתחברות

Option A טובה יותר בשתי שורות (UID, קולישן) וגרועה משמעותית בשתיים (קישור פג, מכשיר אחר) — והשנייה מהן היא כשל שאין לו פתרון נקי, כי ה-UID האנונימי קשור למכשיר.

Google audit 12

שאלה	תשובה
משתמש ב- <code>accounts:signInWithIdp</code> ?	כן, מאומת במקור. <code>OAuthCredential._linkToIdToken</code> <pre>const request = this.buildRequest(); request.idToken = idToken; return signInWithIdp(auth, request);</pre> <code>POST /v1/accounts:signInWithIdp</code> →

שאלה	תשובה
credential ששייך לחשבון קיים	Case B → isAlreadyInUse → auth/credential-already-in-use GoogleAuthProvider.credentialFromError מחזיר את ה-credential מהשגיאה, ולכן אין אימות שני.
ה-fallback שומר ?PendingAction	כן. <code>authUpgrade</code> לא נוגע בו בשום נתיב.
Improved Email Privacy משפיע?	אין סיבה לחשוב שכן. <code>endpoint</code> אחר, ומדיניות הפרטיות נוגעת לנתיבי <code>email/password</code> . ההסתייגות היחידה היא <code>account-exists-with-different-credential</code> — סעיף 9.

13 Apple audit

זוהי Google מבחינה מבנית — `OAuthProvider('apple.com')` מייצר `OAuthCredential`, אותו `_linkToIdToken`, אותו `accounts:signInWithIdp`, אותו טיפול בקולישן דרך `OAuthProvider.credentialFromError`. שני הבדלים:

- **iOS בלבד** — `acquire()` זורק מפורשות על Android. משמעותי ל-Option C: על Android היחיד שנשאר הוא Google.
- **השם חוזר פעם אחת בלבד בחיים**. `acquire` מחזיר `fullName` בנפרד עם הערה מפורשת — אם לא נלכד באותה קריאה, הוא אבוד לתמיד.

14 Recommended option

B — ולהפוך אותה למכוונת. לא לממש כלום עכשיו.

שלוש סיבות:

1. **היא כבר עובדת.** הבעיה שהתכנסנו לפתור לא קיימת — הקישור לא חסום, ומסלול האימייל לא משתמש בקישור מלכתחילה.
 2. **Option A קונה המשכיות UID במחיר שני מצבי כשל גרועים יותר.** "מכשיר אחר" הוא כשל בלי פתרון נקי, ו-UID אנונימי הוא בדיוק הדבר שאין לו ערך כאן: אורח לא מחזיק נתונים, וה-`PendingAction` — הדבר היחיד ששווה לשמר — שורד ממילא כי הוא לא משויך ל-UID.
 3. **Option C מסירה מסלול עובד מ-3.6% מהמשתמשים,** ועל Android מותירה את Google בלבד. אין הצדקה כשאין תקלה.
- Option A שווה לשקול מחדש רק אם יופיע צורך אמיתי בהמשכיות UID — למשל אם אורח יתחיל להחזיק נתונים בשרת. היום הוא לא.
- כיובי `enableImprovedEmailPrivacy` נשקל ונדחתה: הוא מחליש הגנה על `enumeration` בלי לקנות דבר, מכיוון שהקישור אינו חסום מלכתחילה. הוא מתועד כאן כחלופה שנדחתה, לא כהמלצה.

15 Exact implementation scope — אם תאשרו

ניקוי בלבד. אפס שינוי התנהגות, אפס שינוי קונפיג.

שינוי	סוג	סיבה
הסרת ענף <code>email</code> מ- <code>authUpgrade.acquire()</code> ומ- <code>AuthMethod</code> אם אפשרי	קוד מת	אף אחד לא קורא לו; קיומו מרמז על מסלול קישור שלא קיים
תיעוד ב- <code>authUpgrade.ts</code> : אימייל	הערה	שלא ייבנה שוב כ- <code>link</code> בעתיד
הוא Option B במכוון		

שינוי	סוג	סיבה
הסרת ענף מ- <code>auth.ts:246</code> <code>fetchSignInMethodsForEmail</code>	קוד מת	מחזיר <code>[]</code> תמיד תחת המדיניות; <code>EmailAuthScreen</code> כבר מכסה את המקרה

בדיקה שמקבעת: הגיליון מנווט ל- <code>EmailAuth</code> ואינו מקשר	בדיקה	מקבע את ההחלטה
---	-------	----------------

לפני כל אלה, ובנפרד: `probe` מתוקן יחיד ל-0.3 — `accounts:signUp` עם `idToken` — שיסגור סופית את השאלה אם `sign_in_provider` מתהפך. עלות: רשומת `Auth` זמנית אחת, כמו קודם. **דורש אישור נפרד.**

16 האם הממצא משנה את ה-Firebase hotfix candidate

לא. הארטיפקט תקף כפי שהוא, ללא שינוי.
`sha256 25eb0589a8676558...`

ולמעשה הממצא מחזק אותו, כי הוא מסיר את אחד משני התרחישים שהדאיגו:

מסלול שדרוג	מה קורה תחת הארטיפקט
אימייל (Option B, היום)	חשבון חדש, <code>sign_in_provider = password</code> מרגע ההתחברות. אין בכלל טוקן אנונימי אחרי שדרוג — התרחיש שדאגנו לו לא קיים במסלול הזה.
Google / Apple (Case A)	אותו UID. אם הטענה לא מתהפכת מיד — הידרדרות חזותית חולפת. <code>create</code> לא נגוע, ולכן ההרשמה נכתבת.

מה שכן צריך להיאמר: שאלת 0.3 המקורית נשארת פתוחה עבור Google/Apple בלבד, ולא עבור אימייל.

17 Git status / proof no changes

```
branch : perf/firestore-read-costs
HEAD   : 5d899e5 (ללא שינוי מהסבב הקודם)
status : נקי - אפס קבצים לא-מעוקבים, אפס שינויים
```

האיסור	קיים?
אין <code>Auth mutation</code> ב- <code>production</code>	כן — אפס. לא נוצר חשבון.
לא נשלח <code>verification email</code>	כן
לא שונה <code>config</code>	כן — הקונפיג נקרא בלבד
אין <code>deploy</code>	כן
אין שינוי קוד	כן
לא נפתחו <code>iOS / Web</code>	כן

כל הראיות בסבב הזה הגיעו מקריאת מקור ה-SDK ב-`node_modules`, מקריאת קוד המאגר, ומשתי קריאות `read-only` לקונפיג ה-`Auth` של הפרויקט.

